Northwind Analytics Ltd.

SOC 2 Type 2 Report

Report on Northwind Analytics Ltd.'s Description of Its Analytics Platform System and on the Suitability of the Design and Operating Effectiveness of Its Controls Relevant to Security and Availability throughout the period July 1, 2025 to June 30, 2026.

Section 1: Independent Service Auditor's Report

Prepared by Contoso Assurance LLP, independent service auditor. Northwind's Analytics Platform System is hosted on Amazon Web Services (AWS), a subservice organization presented using the carve-out method. Northwind is located in Toronto, ON.

Complementary User Entity Controls

1. User entities are responsible for provisioning and deprovisioning their own users.

2. User entities are responsible for configuring MFA for their users.

3. User entities are responsible for classifying the data they upload.

In our opinion, in all material respects, the controls stated in the description were suitably designed and operated effectively to provide reasonable assurance that the service commitments and system requirements were achieved based on the applicable trust services criteria relevant to security and availability (applicable trust services criteria) set forth in TSP section 100.

Section 2: Management's Assertion

We assert that the controls were effective to provide reasonable assurance that the service commitments and system requirements were achieved based on the applicable trust services criteria relevant to security and availability. Confidentiality criteria (C1.1, C1.2) were not included in the scope of this examination.

Section 3: Description of the System

The Analytics Platform ingests customer event data and produces dashboards.

Section 4: Trust Services Criteria, Related Controls, and Tests of Controls and Results

Criteria	Control #	Control Activity	Test Performed	Results
CC6.1	AC-01	Access to production is restricted to authorized personnel via SSO with MFA.	Inspected SSO configuration.	No exceptions noted.
CC6.2	AC-02	New user access requires manager approval.	Inspected a sample of 25 new hires.	No exceptions noted.
CC6.3	AC-03	Access is removed within 24 hours of termination.	Inspected a sample of 25 terminated employees.	Exception noted: for 2 of 25 sampled terminated employees, access was removed more than 24 hours after the termination date.
CC7.1	VM-01	Authenticated vulnerability scans are performed monthly.	Inspected scan reports for each month.	Exception noted: scan evidence was not available for two of the twelve months in the period.
CC7.2	LM-01	Security events are monitored by a SIEM with alerting.	Observed SIEM dashboards and alert rules.	No exceptions noted.
CC8.1	CM-01	Changes are approved before deployment.	Inspected a sample of 40 changes.	Deviation noted: for 3 of 40 sampled changes, approval was recorded after deployment to production.
A1.2	BC-01	Backups are performed daily and replicated across regions.	Inspected backup job logs.	No exceptions noted.
A1.3	BC-02	Recovery plans are tested annually.	Inspected the most recent test report.	No exceptions noted.